

Windows Security Triage

Metodología de análisis previo al hardening

"Antes de querer proteger un sistema, hay que asegurarse de cómo es el estado actual del mismo. Debemos saber qué estamos protegiendo y ante qué lo hacemos"

Autor: Lautaro Sebastian Figueroa.

Rol: Analista/Consultor de Seguridad Informática.

Fecha: 06/07/2026

Versión: 1.0

Clasificación: Público / Formativo

2. Índice.

3. Propósito del Documento.....	3
3.1 Propósito.....	3
3.3 Audiencia Objetivo.....	3
4. Frameworks y Estándares Aplicables.....	3
4.1 CIS Benchmarks para Windows 10.....	3
4.2 NIST SP 800-61.....	3
4.3 MITRE ATT&CK Framework.....	4
4.4 SANS Forensics & Incident Response.....	4
4.5 Windows Internals (Mark Russinovich).....	4
5. Herramientas de Referencia.....	4
5.1 Herramientas Nativas de Windows.....	4
5.2 Herramientas Avanzadas (Sysinternals Suite).....	5
5.3 Herramientas Forenses Especializadas.....	5
6. Metodología de Trabajo.....	5
6.1 Preparación del Entorno de Análisis.....	5
6.1.1 Creación de Directorios de Trabajo.....	5
6.1.2 Captura de Metadatos del Sistema.....	6
6.1.3 Documentación de Fecha y Hora.....	6
6.2 Fase 1: Captura de Datos Volátiles.....	6
6.2.1 Análisis de Procesos.....	6
6.2.2 Análisis de Conexiones de Red.....	7
6.2.3 Análisis de Usuarios y Sesiones.....	8
6.2.4 Análisis de Servicios de Windows.....	8
6.3 Fase 2: Análisis de Mecanismos de Persistencia.....	9
6.3.1 Análisis de Registro de Windows.....	9
6.3.2 Análisis de Tareas Programadas.....	10
6.3.3 Análisis de Carpetas de Inicio.....	10
6.4 Fase 3: Análisis de Artefactos de Actividad de Usuario.....	11
6.4.1 Análisis de Historial de Ejecución (RunMRU).....	11
6.4.2 Análisis de Archivos Recientes.....	11
6.4.3 Análisis de Prefetch.....	12
6.5 Fase 4: Análisis de Configuración de Seguridad.....	12
6.5.1 Políticas de Auditoría.....	12
6.5.2 Políticas de Seguridad Local.....	13
6.5.3 Configuración de Firewall.....	13
6.6 Fase 5: Análisis de Eventos de Seguridad.....	13
6.6.1 Exportación de Logs Críticos.....	14
6.6.2 Filtrado de Eventos Clave.....	14
6.7 Fase 6: Integración de Sigcheck con VirusTotal (Análisis de reputación y firmas)....	15
6.7.1 Preparación y Aceptación de Términos.....	15
6.7.2 Análisis de archivos con verificación de firma y reputación.....	16
6.7.3 Interpretación de Resultados y Acciones a Tomar.....	17
7. Conclusión.....	17

3. Propósito del Documento

3.1 Propósito

Establecer una metodología sistemática y reproducible para el análisis forense de estaciones de trabajo Windows 10, previo a la aplicación de controles de seguridad basados en estándares reconocidos como el CIS Benchmark.

3.2 Alcance

- Sistemas Operativos: Windows 10 home y Pro/Enterprise (versiones 1909 y superiores)
- Arquitectura: x64 (64 bits)
- Entorno: Estaciones de trabajo en entornos corporativos y personales
- Exclusiones: Servidores Windows y sistemas legacy

3.3 Audiencia Objetivo

- Administradores de sistemas
 - Ingenieros de seguridad de infraestructura
 - Analistas de SOC (Security Operations Center)
 - Profesionales de ciberseguridad en formación
-

4. Frameworks y Estándares Aplicables

4.1 CIS Benchmarks para Windows 10

- Versión: 2.0.0 (última disponible)
- Niveles de configuración:
 - Nivel 1 (L1): Configuraciones básicas recomendadas para entornos corporativos, con mínimo impacto en funcionalidad y rendimiento.
 - Nivel 2 (L2): Configuraciones avanzadas para entornos de alta seguridad, priorizando la seguridad sobre la usabilidad.
- Áreas de cobertura: Políticas de cuenta, auditoría, firewall, servicios, registro, etc.

4.2 NIST SP 800-61

- Enfoque: Guía para el manejo de incidentes de seguridad
- Aplicación al informe: Metodología de respuesta a incidentes y preservación de evidencia

4.3 MITRE ATT&CK Framework

- Enfoque: Matriz de tácticas y técnicas utilizadas por atacantes
- Aplicación al informe: Identificación de técnicas de persistencia, evasión y ejecución durante el análisis forense

4.4 SANS Forensics & Incident Response

- Metodologías: Reconocidas para respuesta a incidentes y análisis forense digital
- Principios clave: Orden de volatilidad, cadena de custodia, preservación de evidencia

4.5 Windows Internals (Mark Russinovich)

- Enfoque: Arquitectura interna de Windows
- Aplicación: Comprensión de procesos, servicios, registro y sistema de archivos

5. Herramientas de Referencia

5.1 Herramientas Nativas de Windows

Herramienta	Propósito	Comando de ejemplo
tasklist	Listar procesos en ejecución	tasklist /v /m
netstat	Analizar conexiones de red	netstat -abno
reg	Consultar y modificar registro	reg query HKLM\Software
schtasks	Gestionar tareas programadas	schtasks /query /v
wmic	Interfaz WMI para administración	wmic process get Commandline
wevtutil	Gestionar logs de eventos	wevtutil epl Security
auditpol	Configurar políticas de auditoría	auditpol /get /category:*
netsh	Configurar red y firewall	netsh advfirewall show
systeminfo	Información del sistema	systeminfo

5.2 Herramientas Avanzadas (Sysinternals Suite)

Herramienta	Propósito
Autoruns	Analizar todos los puntos de persistencia del sistema
Process Explorer	Visión detallada de procesos y sus dependencias
TCPView	Monitoreo avanzado de conexiones de red
ProcMon	Monitoreo en tiempo real de registro, archivos y procesos

5.3 Herramientas Forenses Especializadas

Herramienta	Propósito
KAPE (Kroll Artifact Parser and Extractor)	Adquisición y extracción de artefactos forenses
FTK Imager	Creación de imágenes forenses de discos
Volatility	Análisis de volcados de memoria RAM
LOLBAS Project	Base de datos de binarios legítimos usados maliciosamente

6. Metodología de Trabajo

6.1 Preparación del Entorno de Análisis

Objetivo: Establecer un ambiente de trabajo organizado y documentado para preservar la integridad de la evidencia.

6.1.1 Creación de Directorios de Trabajo

```
mkdir C:\Forensics
mkdir C:\Forensics\01_Adquisicion
mkdir C:\Forensics\02_Analisis
mkdir C:\Forensics\03_Reportes
mkdir C:\Forensics\04_Evidencia
```

6.1.2 Captura de Metadatos del Sistema

Información básica del sistema

- systeminfo > C:\Forensics\01_Adquisicion\00_systeminfo.txt

Versión y fecha de instalación del SO

- wmic os get Caption,Version,LastBootUpTime,InstallDate >>
C:\Forensics\01_Adquisicion\00_systeminfo.txt

Información de hardware y BIOS

- wmic bios get SerialNumber,Version >>
C:\Forensics\01_Adquisicion\00_hardware.txt
- wmic cpu get Name,NumberOfCores >>
C:\Forensics\01_Adquisicion\00_hardware.txt

Variables de entorno

- set > C:\Forensics\01_Adquisicion\00_environment.txt

Hash de archivos críticos para verificar integridad futura

- certutil -hashfile C:\Windows\System32\ntoskrnl.exe SHA256 >
C:\Forensics\01_Adquisicion\00_integridad_base.txt
- certutil -hashfile C:\Windows\System32\svchost.exe SHA256 >>
C:\Forensics\01_Adquisicion\00_integridad_base.txt
- certutil -hashfile C:\Windows\System32\lsass.exe SHA256 >>
C:\Forensics\01_Adquisicion\00_integridad_base.txt

6.1.3 Documentación de Fecha y Hora

Registrar el timestamp exacto del inicio del análisis

- echo Fecha y hora de inicio del análisis: %date% %time% >
C:\Forensics\01_Adquisicion\00_timestamp.txt

6.2 Fase 1: Captura de Datos Volátiles

Objetivo: Recolectar información del sistema en ejecución antes de cualquier intervención que pueda alterar el estado.

6.2.1 Análisis de Procesos

Estado general de procesos con módulos cargados

- tasklist /v /m > C:\Forensics\01_Adquisicion\01_procesos_completos.txt

Procesos con información de servicio asociado

- tasklist /svc > C:\Forensics\01_Adquisicion\01_procesos_servicios.txt

Línea de comandos completa de cada proceso (CRÍTICO)

- wmic process get
Name,Commandline,Description,ProcessID,ParentProcessID,ExecutablePath
/format:csv > C:\Forensics\01_Adquisicion\01_wmic_procesos.csv

Procesos con firma digital no verificada

- wmic process get Name,ExecutablePath /format:csv | findstr /V "Microsoft Windows"
> C:\Forensics\01_Adquisicion\01_procesos_no_firmados.txt

Criterios de evaluación:

- Procesos con nombres que simulan ejecutables legítimos: svch0st.exe, expl0rer.exe, services.exe
- Binarios ejecutándose desde rutas no estándar: C:\Temp\, C:\Users*\AppData\Roaming\
- Procesos con línea de comandos sospechosa: scripts PowerShell ofuscados, ejecución con argumentos ocultos
- Relaciones padre-hijo inusuales: winword.exe lanzando powershell.exe

6.2.2 Análisis de Conexiones de Red

Conexiones activas con proceso asociado y actualización cada 5 segundos

- netstat -abno 5 > C:\Forensics\01_Adquisicion\02_netstat_realtime.txt

Conexiones actuales sin repetición

- netstat -abno > C:\Forensics\01_Adquisicion\02_netstat_snapshot.txt

Tabla de enrutamiento

- route print > C:\Forensics\01_Adquisicion\02_tabla_enrutamiento.txt

Caché de resolución DNS

- ipconfig /displaydns > C:\Forensics\01_Adquisicion\02_cache_dns.txt

Interfaces de red y configuraciones

- ipconfig /all > C:\Forensics\01_Adquisicion\02_interfaces_red.txt

Conexiones establecidas con IPs externas

- netstat -an | findstr ESTABLISHED >
C:\Forensics\01_Adquisicion\02_conexiones_establecidas.txt

Conexiones en estado LISTENING (escuchando)

- netstat -an | findstr LISTENING >
C:\Forensics\01_Adquisicion\02_puertos_escucha.txt

Criterios de evaluación:

- Conexiones salientes de procesos que no deberían tener actividad de red

- Puertos no estándar: 4444, 1337, 31337 (comunes en malware)
- Conexiones a IPs sospechosas (verificar con herramientas como VirusTotal)
- Conexiones a puertos administrativos remotos (445, 3389, 135, 139) sin razón aparente

6.2.3 Análisis de Usuarios y Sesiones

Sesiones activas actuales

- query user > C:\Forensics\01_Adquisicion\03_sesiones_activas.txt

Usuarios locales

- net user > C:\Forensics\01_Adquisicion\03_usuarios_locales.txt

Usuarios en el grupo de administradores

- net localgroup administrators > C:\Forensics\01_Adquisicion\03_administradores.txt

Usuarios con acceso remoto habilitado

- net localgroup "Remote Desktop Users" >
C:\Forensics\01_Adquisicion\03_rdp_usuarios.txt

Último inicio de sesión de cada usuario

- wmic netlogin get Name,LastLogon /format:csv >
C:\Forensics\01_Adquisicion\03_ultimos_logins.csv

Criterios de evaluación:

- Usuarios desconocidos en el grupo Administradores
- Cuentas de usuario creadas recientemente (EventID 4720)
- Múltiples sesiones activas en un equipo que debería ser de uso personal

6.2.4 Análisis de Servicios de Windows

Todos los servicios y su estado

- sc query state= all > C:\Forensics\01_Adquisicion\04_servicios_todos.txt

Servicios en ejecución

- sc query state= running > C:\Forensics\01_Adquisicion\04_servicios_ejecucion.txt

Servicios con inicio automático

- sc query state= all | findstr /C:"START_TYPE" /C:"AUTO_START" >
C:\Forensics\01_Adquisicion\04_servicios_auto.txt

Servicios que no son de Microsoft

- wmic service get Name,DisplayName,PathName,StartMode,State /format:csv | findstr /V "C:\Windows\System32" > C:\Forensics\01_Adquisicion\04_servicios_no_ms.txt

Criterios de evaluación:

- Servicios con nombres que imitan a los legítimos

- Servicios ejecutándose desde ubicaciones no estándar
 - Servicios con archivos ejecutables que no tienen firma digital de Microsoft
-

6.3 Fase 2: Análisis de Mecanismos de Persistencia

Objetivo: Identificar puntos de entrada y mecanismos que permitan ejecución automática de programas.

6.3.1 Análisis de Registro de Windows

Crear directorio específico para análisis de registro

- mkdir C:\Forensics\01_Adquisicion\05_Registro

Keys principales de persistencia por usuario

- reg query HKCU\Software\Microsoft\Windows\CurrentVersion\Run > C:\Forensics\01_Adquisicion\05_Registro\HKCU_Run.txt
- reg query HKCU\Software\Microsoft\Windows\CurrentVersion\RunOnce > C:\Forensics\01_Adquisicion\05_Registro\HKCU_RunOnce.txt

Keys principales de persistencia del sistema

- reg query HKLM\Software\Microsoft\Windows\CurrentVersion\Run > C:\Forensics\01_Adquisicion\05_Registro\HKLM_Run.txt
- reg query HKLM\Software\Microsoft\Windows\CurrentVersion\RunOnce > C:\Forensics\01_Adquisicion\05_Registro\HKLM_RunOnce.txt
- reg query HKLM\Software\Microsoft\Windows\CurrentVersion\RunOnceEx > C:\Forensics\01_Adquisicion\05_Registro\HKLM_RunOnceEx.txt

Winlogon - persistencia menos común pero peligrosa

- reg query "HKLM\Software\Microsoft\Windows NT\CurrentVersion\Winlogon" > C:\Forensics\01_Adquisicion\05_Registro\HKLM_Winlogon.txt
- reg query "HKCU\Software\Microsoft\Windows NT\CurrentVersion\Winlogon" > C:\Forensics\01_Adquisicion\05_Registro\HKCU_Winlogon.txt

Extensiones de shell y asociaciones de archivos

- reg query HKCR\exefile\shell\open\command > C:\Forensics\01_Adquisicion\05_Registro\HKCR_exe_assoc.txt
- reg query HKCR\comfile\shell\open\command > C:\Forensics\01_Adquisicion\05_Registro\HKCR_com_assoc.txt
- reg query HKCR\scrfile\shell\open\command > C:\Forensics\01_Adquisicion\05_Registro\HKCR_scr_assoc.txt

Puntos de persistencia en servicios

- reg query HKLM\System\CurrentControlSet\Services > C:\Forensics\01_Adquisicion\05_Registro\HKLM_Services.txt

- reg query HKLM\SYSTEM\CurrentControlSet\Control\SafeBoot >
C:\Forensics\01_Adquisicion\05_Registro\HKLM_SafeBoot.txt

Criterios de evaluación:

- Entradas que apunten a rutas temporales o AppData
- Comandos con PowerShell ofuscados (parámetros -enc, -e, -WindowStyle Hidden)
- Ejecución de scripts desde ubicaciones remotas (IEX con DownloadString)
- Entradas con nombres que imitan a software legítimo pero ejecutan otro binario

6.3.2 Análisis de Tareas Programadas

Listado completo de tareas programadas en formato detallado

- schtasks /query /fo LIST /v >
C:\Forensics\01_Adquisicion\06_tareas_programadas.txt

Tareas con nombres sospechosos

- schtasks /query /fo LIST /v | findstr /I "update java flash adobe" >
C:\Forensics\01_Adquisicion\06_tareas_sospechosas.txt

Tareas que ejecutan scripts de PowerShell

- schtasks /query /fo LIST /v | findstr /I "powershell" >
C:\Forensics\01_Adquisicion\06_tareas_powershell.txt

Tareas creadas en los últimos 30 días

- powershell -Command "Get-ScheduledTask | Where-Object {\$_.Date -gt (Get-Date).AddDays(-30)}" > C:\Forensics\01_Adquisicion\06_tareas_recientes.txt

Criterios de evaluación:

- Tareas con nombres que imitan a actualizaciones legítimas
- Tareas que se ejecutan con privilegios elevados (SYSTEM, Administrator)
- Tareas que ejecutan código ofuscado o desde ubicaciones temporales
- Tareas con triggers (disparadores) inusuales: al inicio de sesión, en intervalos cortos

6.3.3 Análisis de Carpetas de Inicio

Carpeta de inicio del usuario actual

- dir "%APPDATA%\Microsoft\Windows\Start Menu\Programs\Startup" /O-D /T:W >
C:\Forensics\01_Adquisicion\07_startup_user.txt

Carpeta de inicio para todos los usuarios

- dir "C:\ProgramData\Microsoft\Windows\Start Menu\Programs\StartUp" /O-D /T:W >
C:\Forensics\01_Adquisicion\07_startup_all.txt

Verificar contenido de los accesos directos

- >for %i in ("%APPDATA%\Microsoft\Windows\Start Menu\Programs\Startup*.lnk") do
@echo %i & type "%i" | findstr /I "Temp Users" >
C:\Forensics\01_Adquisicion\07_startup_analisis.txt

Criterios de evaluación:

- Accesos directos a archivos ejecutables en ubicaciones temporales
 - Archivos .vbs, .ps1, .js, .hta en lugar de ejecutables .exe
 - Archivos con fechas de creación recientes
-

6.4 Fase 3: Análisis de Artefactos de Actividad de Usuario

Objetivo: Establecer una línea de tiempo de actividad y detectar comportamientos anómalos.

6.4.1 Análisis de Historial de Ejecución (RunMRU)

Comandos ejecutados desde el cuadro de diálogo Ejecutar

- `reg query "HKCU\Software\Microsoft\Windows\CurrentVersion\Explorer\RunMRU" > C:\Forensics\01_Adquisicion\08_runmru.txt`

Obtener timestamp del último comando ejecutado

- `>powershell -Command "Get-ItemProperty -Path 'HKCU:\Software\Microsoft\Windows\CurrentVersion\Explorer\RunMRU' | Select-Object *" > C:\Forensics\01_Adquisicion\08_runmru_metadata.txt`

Criterios de evaluación:

- Comandos PowerShell ofuscados o con parámetros ocultos
- Ejecución de scripts desde ubicaciones temporales
- Descargas desde Internet mediante IEX (New-Object Net.WebClient).DownloadString()
- Comandos reg add que añaden persistencia

6.4.2 Análisis de Archivos Recientes

Listado de archivos recientes ordenados por fecha de modificación

- `dir "%APPDATA%\Microsoft\Windows\Recent" /O-D /T:W > C:\Forensics\01_Adquisicion\09_archivos_recientes.txt`

Archivos .lnk sospechosos

- `dir "%APPDATA%\Microsoft\Windows\Recent\*.lnk" /O-D /T:W > C:\Forensics\01_Adquisicion\09_lnk_recientes.txt`

Verificar destino de los archivos .lnk

- `for %i in ("%APPDATA%\Microsoft\Windows\Recent\*.lnk") do @echo %i & wmic path Win32_ShortcutFile where "Name='%APPDATA%\Microsoft\Windows\Recent\%~nxi'" get Target /format:list > C:\Forensics\01_Adquisicion\09_lnk_destinos.txt`

Criterios de evaluación:

- Archivos abiertos a horas inusuales (ej. 3:00 AM)
- Documentos que no recuerdas haber abierto
- Archivos que apuntan a ejecutables en ubicaciones temporales

6.4.3 Análisis de Prefetch

Archivos Prefetch (registro de programas ejecutados)

- `dir C:\Windows\Prefetch /O-D > C:\Forensics\01_Adquisicion\10_prefetch.txt`

Filtrar archivos Prefetch sospechosos

- `dir C:\Windows\Prefetch\*.pf /O-D | findstr /I "temp downloads appdata" > C:\Forensics\01_Adquisicion\10_prefetch_sospechosos.txt`

Criterios de evaluación:

- Programas ejecutados desde ubicaciones temporales
 - Herramientas de hacking con nombres comunes (mimikatz, procdump, psexec)
-

6.5 Fase 4: Análisis de Configuración de Seguridad

Objetivo: Evaluar el estado actual de las configuraciones de seguridad para identificar desviaciones de las mejores prácticas.

6.5.1 Políticas de Auditoría

Verificar políticas de auditoría configuradas

- `auditpol /get /category:* > C:\Forensics\02_Analisis\11_politicas_auditoria.txt`

Políticas de auditoría específicas para login

- `auditpol /get /subcategory:"Logon" > C:\Forensics\02_Analisis\11_politicas_logon.txt`

Políticas de auditoría para cambios de objeto

- `auditpol /get /subcategory:"SAM" > C:\Forensics\02_Analisis\11_politicas_sam.txt`
- `auditpol /get /subcategory:"Kernel Object" > C:\Forensics\02_Analisis\11_politicas_kernel.txt`

Criterios de evaluación:

- Falta de auditoría en eventos críticos (inicios de sesión, cambios de grupo, creación de usuarios)

6.5.2 Políticas de Seguridad Local

Políticas de contraseñas

- `net accounts > C:\Forensics\02_Analisis\12_politicas_contraseñas.txt`

Políticas de bloqueo de cuentas

- reg query "HKLM\SYSTEM\CurrentControlSet\Services\Netlogon\Parameters" > C:\Forensics\02_Analisis\12_politicas_bloqueo.txt

Políticas UAC (Control de Cuentas de Usuario)

- reg query "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System" > C:\Forensics\02_Analisis\12_politicas_uac.txt

Criterios de evaluación:

- Contraseñas sin complejidad requerida
- Sin límite de intentos de inicio de sesión (bloqueo de cuentas)
- UAC deshabilitado o en nivel bajo

6.5.3 Configuración de Firewall

Configuración general del firewall

- netsh advfirewall show allprofiles > C:\Forensics\02_Analisis\13_firewall_config.txt

Reglas de firewall entrantes

- netsh advfirewall firewall show rule name=all dir=in > C:\Forensics\02_Analisis\13_firewall_in.txt

Reglas de firewall salientes

- netsh advfirewall firewall show rule name=all dir=out > C:\Forensics\02_Analisis\13_firewall_out.txt

Puertos abiertos en el firewall

- netsh advfirewall firewall show rule name=all | findstr /C:"LocalPort" > C:\Forensics\02_Analisis\13_firewall_puertos.txt

Criterios de evaluación:

- Reglas que permiten conexiones entrantes desde cualquier IP (Any)
- Puertos administrativos abiertos (RDP 3389, SMB 445, NetBIOS 139/137)
- Excepciones para aplicaciones en ubicaciones no estándar

6.6 Fase 5: Análisis de Eventos de Seguridad

Objetivo: Revisar logs de eventos para identificar incidentes o comportamientos anómalos pasados.

6.6.1 Exportación de Logs Críticos

Crear directorio para logs

- mkdir C:\Forensics\01_Adquisicion\14_EventLogs

Exportar logs de seguridad (crítico para auditoría)

- wevtutil epl Security C:\Forensics\01_Adquisicion\14_EventLogs\Security.evtx

Exportar logs de sistema

- wevtutil epl System C:\Forensics\01_Adquisicion\14_EventLogs\System.evtx

Exportar logs de aplicaciones

- wevtutil epl Application C:\Forensics\01_Adquisicion\14_EventLogs\Application.evtx

Exportar logs de PowerShell

- wevtutil epl "Windows PowerShell"
C:\Forensics\01_Adquisicion\14_EventLogs\PowerShell.evtx

Exportar logs de Microsoft-Windows-Sysmon (si está instalado)

- wevtutil epl "Microsoft-Windows-Sysmon/Operational"
C:\Forensics\01_Adquisicion\14_EventLogs\Sysmon.evtx

6.6.2 Filtrado de Eventos Clave

Crear directorio para análisis de eventos

- mkdir C:\Forensics\02_Analisis\14_Eventos_Filtrados

Eventos de creación de usuarios (4720)

- wevtutil qe Security /q:"*[System[(EventID=4720)]]" /c:100 /f:text >
C:\Forensics\02_Analisis\14_Eventos_Filtrados\eventos_4720.txt

Eventos de inicio de sesión exitoso (4624)

- wevtutil qe Security /q:"*[System[(EventID=4624)]]" /c:100 /f:text >
C:\Forensics\02_Analisis\14_Eventos_Filtrados\eventos_4624.txt

Eventos de inicio de sesión fallido (4625)

- wevtutil qe Security /q:"*[System[(EventID=4625)]]" /c:100 /f:text >
C:\Forensics\02_Analisis\14_Eventos_Filtrados\eventos_4625.txt

Eventos de cambio de grupo de seguridad (4732, 4733)

- wevtutil qe Security /q:"*[System[(EventID=4732)]]" /c:100 /f:text >
C:\Forensics\02_Analisis\14_Eventos_Filtrados\eventos_4732.txt
- wevtutil qe Security /q:"*[System[(EventID=4733)]]" /c:100 /f:text >
C:\Forensics\02_Analisis\14_Eventos_Filtrados\eventos_4733.txt

Eventos de creación de tareas programadas (4698)

- wevtutil qe Security /q:"*[System[(EventID=4698)]]" /c:100 /f:text >
C:\Forensics\02_Analisis\14_Eventos_Filtrados\eventos_4698.txt

Eventos de ejecución de PowerShell (4104 - script block logging)

- wevtutil qe "Microsoft-Windows-PowerShell/Operational" /q:"*[System[(EventID=4104)]]" /c:100 /f:text > C:\Forensics\02_Analisis\14_Eventos_Filtrados\eventos_4104.txt

Eventos a monitorear:

EventID	Descripción	Importancia
4624	Inicio de sesión exitoso	Alto - identificar accesos no autorizados
4625	Inicio de sesión fallido	Alto - detectar ataques de fuerza bruta
4720	Creación de usuario	Crítico - posible creación de backdoor
4732	Adición a grupo de seguridad	Crítico - elevación de privilegios
4698	Creación de tarea programada	Alto - posible mecanismo de persistencia
4104	Ejecución de script PowerShell	Crítico - detección de scripts maliciosos
1102	Borrado de log de eventos	Crítico - intento de ocultar evidencia

6.7 Fase 6: Integración de Sigcheck con VirusTotal (Análisis de reputación y firmas)

Objetivo: Verificar la integridad y reputación de los archivos del sistema, identificando aquellos que no están firmados digitalmente o que tienen detecciones positivas en VirusTotal. Esta fase cruza la confianza local con la inteligencia global de mas de 70 motores antivirus.

6.7.1 Preparación y Aceptación de Términos

Para usar las funcionalidades de VT, es necesario aceptar sus terminos de servicio. Puedes hacerlo de forma interactiva en la primera ejecución o con el parametro -vt.

6.7.2 Análisis de archivos con verificación de firma y reputación

El parámetro -v consulta a VirusTotal usando el hash del archivo. Combinando con -u, filtra la salida para mostrar solo archivos no firmados, desconocidos o con detecciones positivas.

Comandos clave y su aplicación:

Análisis General del Sistema

Busca archivos ejecutables en todo el sistema que no tengan firma digital o que tengan mala reputación en VirusTotal. Esto es útil para una auditoría inicial.

Escanea recursivamente todo el disco C:\, mostrando solo ejecutables con problemas de firma o reputación.

- sigcheck -u -e -s -v C:\ >
C:\Forensics\01_Adquisicion\15_sigcheck_reputacion_general.txt
- -u: Filtra la salida. Si se usa con -v, muestra archivos que VirusTotal desconoce o que tienen detección positiva. Si no se usa -v, muestra solo archivos no firmados .
- -e: Restringe el análisis a imágenes ejecutables (.exe, .dll, .sys, etc.), independientemente de su extensión, lo que agiliza el proceso.
- -s: Habilita el escaneo recursivo de subdirectorios .
- -v: Habilita la consulta a VirusTotal. La primera vez que se usa en un sistema, puede requerir aceptar los términos .

Análisis Focalizado en Directorios Críticos

Es recomendable comenzar con directorios críticos para una respuesta más rápida. Este comando se enfoca en los ejecutables de C:\Windows\System32.

Escanea directorios de sistema críticos, exportando resultados a CSV.

- sigcheck -u -e -v C:\Windows\System32 C:\Windows\SysWOW64 >
C:\Forensics\01_Adquisicion\15_sigcheck_system32.txt

Generación de Reporte CSV para Análisis Offline

Para sistemas sin conexión a Internet, se puede generar un archivo CSV con los hashes de todos los ejecutables. Este archivo se transfiere a una máquina con acceso a Internet para la consulta .

Guarda hashes de todos los ejecutables del sistema en un CSV.

- sigcheck -h -ct -s -e C:\ > C:\Forensics\01_Adquisicion\15_hashes_sistema.csv
- -h: Calcula y muestra los hashes criptográficos de los archivos .
- -ct: Formatea la salida como CSV con delimitador de tabulador, ideal para hojas de cálculo o scripts.

Posteriormente, en la máquina con Internet, se usa el parámetro -o para consultar VirusTotal usando el CSV generado .

(Ejecutar en una máquina con Internet) Consulta VirusTotal usando los hashes del archivo CSV.

- sigcheck -o -vr hashes_sistema.csv > C:\Forensics\02_Analisis\15_resultados_virustotal.csv
- -o: Especifica que la entrada es un archivo CSV con hashes previamente capturados.
- -vr: Consulta VirusTotal y, si un archivo tiene detecciones positivas, intenta abrir el informe en el navegador predeterminado .

Subida de Archivos Desconocidos (Avanzado)

Si un archivo no está en la base de datos de VirusTotal, y se tiene conexión a Internet, se puede optar por subirlo para su análisis. Esto debe hacerse con precaución y entendiendo que la información del archivo puede ser compartida con la comunidad .

Sube archivos desconocidos a VirusTotal para su análisis.

- sigcheck -vrs C:\Users\Usuario\Descargas\sospechoso.exe
- -vs: Si el hash no se encuentra en VirusTotal, sube el archivo completo para su análisis . Los resultados pueden tardar 5 minutos o más en estar disponibles.
- -r: Intenta abrir el informe en el navegador si el archivo tiene detecciones positivas.

6.7.3 Interpretación de Resultados y Acciones a Tomar

- Archivos No Firmados (-u sin -v): Indica que el archivo no tiene una firma digital válida de un editor de confianza. Aunque muchos archivos legítimos no están firmados (ej. herramientas de terceros), en directorios críticos de Windows es una gran anomalía que merece investigación .
- Archivos con Detecciones Positivas (-v): La salida mostrará un contador como (X/Y) donde X es el número de motores que detectaron el archivo y Y el total consultado. Un número positivo (X>0) indica que VirusTotal considera que hay una amenaza potencial. El informe en VirusTotal proporcionará los nombres de las detecciones y detalles técnicos.
- Archivos Desconocidos (Unknown): Significa que el hash del archivo no está en la base de datos de VirusTotal. Esto no es necesariamente malo, pero es un punto de atención, especialmente si es un archivo nuevo o de origen no confiable. Puedes optar por subirlo (con el parámetro -s) para su análisis comunitario.

7. Conclusión

El objetivo del triage no es determinar con certeza absoluta que una estación de trabajo está comprometida, sino reunir y correlacionar evidencia suficiente para decidir si el activo

puede continuar hacia un proceso de hardening o requiere un análisis forense más profundo.

En seguridad informática, un hardening efectivo comienza mucho antes de aplicar configuraciones: comienza validando que el entorno sea confiable.